

ComplianceGPT: A Citation-Contract Architecture for Mechanically Verifiable Compliance Question Answering

Anonymous CVPR submission

Paper ID *****

Abstract

001 Compliance question answering is a high-stakes setting
002 where fluent retrieval-augmented generation is not enough.
003 Analysts need answers that are revision-correct, trace-
004 able to authoritative clause text, and safe when a stan-
005 dard intentionally leaves values unresolved. This pa-
006 per presents ComplianceGPT, a citation-contract architec-
007 ture for mechanically verifiable compliance question an-
008 swering over NIST SP 800-53 Rev4 and Rev5. The sys-
009 tem combines clause-level version-aware retrieval, query
010 rewriting, a bounded selector-only language model step,
011 deterministic final answer assembly from a Canonical
012 Clause Store, explicit safe statuses for NO_EVIDENCE and
013 PARAMS_REQUIRED, and verifier-based contract check-
014 ing. We evaluate three layers. RQ1 studies retrieval through
015 an S1 to S7 ladder and shows that the full retrieval stack is
016 strongest, but that retrieval alone does not solve the task.
017 RQ2 compares ComplianceGPT against a matched genera-
018 tive RAG baseline that uses the same revision-scoped cor-
019 pus, the same retrieval path, and the same general model
020 family but writes the final answer freely. RQ3 studies
021 organization-defined parameters in the no-profile setting.
022 The decisive result is that the generative baseline often
023 reaches the right control but fails at safe final answer con-
024 struction. On Rev5, ComplianceGPT reaches 0.64 Audit
025 Ready Answer rate against 0.22 for the generative base-
026 line, while ODP correct handling is 1.00 against 0.00. On
027 Rev4, the corresponding Audit Ready Answer rates are 0.75
028 and 0.22, again with perfect versus zero ODP-correct han-
029 dling. These results support the central claim of the system:
030 strong retrieval is necessary, but the decisive gain comes
031 from citation-contract answer construction rather than free-
032 form final generation.

033 1. Introduction

034 Organizations that handle regulated data must comply with
035 standards that are detailed, revised over time, and exam-

ined in audit. In practice, this work is still highly manual
and difficult to scale [2]. Auditors must search large com-
pliance standards, interpret formal control language, con-
nect related clauses, and prepare artifacts that others can
review [3]. Historically, this workflow has relied on lexical
retrieval methods such as keyword search and BM25 [4].

These tools are useful for navigation, but they do not
solve the full compliance question-answering problem. Op-
erational questions are often phrased in practical language,
while compliance frameworks state obligations in formal
and abstract language [5]. Relevant evidence is also often
distributed across related controls, enhancements, and guid-
ance, so the analyst must reconstruct the governing obliga-
tion by hand [6]. This process brings a high cognitive load.

1.1. Problem

Large language models (LLMs) combined with retrieval-
augmented generation (RAG) have emerged as an appeal-
ing way to address this gap [7]. An LLM can help inter-
pret a user's intent and rewrite a question into language that
retrieval can match more effectively [8]. It can also help
combine evidence from multiple passages into a single re-
sponse. However, the same generative flexibility creates a
direct risk: hallucination, meaning content that is unsup-
ported by the source, unverifiable from the available evi-
dence, or simply false [9]. Even under RAG, generated an-
swers can still contain unsupported or contradictory claims
relative to the retrieved evidence [10]. In compliance, this is
not a small wording problem. It is a grounding and verifica-
tion failure: the system can produce an answer that sounds
complete and authoritative even when the cited text does not
support it [11], which directly causes security breaches and
financial penalties.

These issues are especially acute in NIST SP 800-53 be-
cause many controls contain organization-defined paramet-
ers. In such cases, the standard defines what must be spec-
ified, but not the value itself; that value must come from
the adopting organization. This means that a system can re-
trieve the correct control and still produce a wrong answer
by inventing a missing parameter value and presenting it as

075 if it were stated in the standard. A safe compliance assistant
076 must therefore preserve the unresolved state when required
077 values are unavailable rather than fabricate a false-complete
078 answer.

079 To address this problem, we present ComplianceGPT,
080 a citation-contract architecture for mechanically verifiable
081 compliance question answering over NIST SP 800-53 Revi-
082 sion 4 [12] and Revision 5 [13]. Its central design principle
083 is simple: use the language model to help find and organize
084 evidence, but do not allow it to freely write the final compli-
085 ance answer. The system therefore combines clause-level,
086 version-aware retrieval over a Canonical Clause Store, con-
087 trolled query rewriting, a bounded selector-only language
088 model step, deterministic final answer assembly from au-
089 thoritative source text, and verifier-based contract checking.
090 When the available evidence does not support a complete
091 grounded response, the system returns explicit safe statuses,
092 including NO_EVIDENCE and PARAMS_REQUIRED.

093 To guide the study, we investigate the following research
094 questions (RQs):

- 095 • **RQ1:** To what extent does clause-level, version-aware re-
096 trieval improve evidence selection for compliance ques-
097 tions affected by terminology mismatch and fragmented
098 source text?
- 099 • **RQ2.** How does replacing free-text final answer gener-
100 ation with deterministic citation-contract assembly affect
101 audit validity, including verbatim grounding and revision
102 consistency, relative to matched generative RAG base-
103 lines?
- 104 • **RQ3.** Can explicit resolution policies for organization-
105 defined parameters reduce value fabrication while pre-
106 serving useful coverage on answerable compliance ques-
107 tions?

108 1.2. Contributions

109 Building on prior advances in retrieval, regulatory NLP,
110 and grounded language generation, we make three contri-
111 butions.

- 112 1. We introduce ComplianceGPT, a citation-contract archi-
113 tecture that decouples probabilistic evidence selection
114 from deterministic final answer realization for compli-
115 ance question answering.
- 116 2. We evaluate the system along three layers that are of-
117 ten conflated in end-to-end evaluation: retrieval quality,
118 final answer construction under matched retrieval condi-
119 tions, and the handling of missing organization-defined
120 parameters.
- 121 3. We demonstrate that strong retrieval alone is insuffi-
122 cient for safe compliance question answering. Even
123 when generative baselines reach the correct control
124 neighborhood under matched retrieval conditions, they
125 can still fail at final answer construction by producing
126 false-complete answers on parameter-bearing questions.

ComplianceGPT improves audit-ready output by surfac-
ing unresolved constraints rather than fabricating com-
pletion.

2. Related Work

2.1. Regulatory and Compliance Text Analysis

Research on legal and regulatory NLP first focused on
making complex legal language computationally usable.
Chalkidis et al. showed that obligations and prohibitions
can be extracted from contracts with domain-aware neural
models [14]. Later work moved from extraction to retrieval.
Chalkidis et al. framed compliance analysis as document-
to-document retrieval over legislation and showed that sim-
ple text similarity is a weak fit for long, densely cross-
referenced regulatory texts [15]. Abualhaija et al. moved
closer to analyst support by using question answering to
help users understand compliance requirements across mul-
tiple documents [16]. More recently, Gokhan et al. in-
troduced the RIRAG setting and associated benchmarks,
making regulatory retrieval and answer generation a dis-
tinct problem rather than a minor variant of general legal
QA [17].

This literature establishes an important point: compli-
ance work is not just text classification or document lookup.
The analyst must connect formal regulatory language to
practical questions and recover the governing obligation
from distributed source text. But most prior work still stud-
ies retrieval, understanding, or answer generation as sepa-
rate capabilities. It does not fully address a stricter require-
ment that matters in compliance settings: the final answer
must remain traceable to authoritative text from a specific
revision of the standard.

2.2. Retrieval and Multi-Passage Answer Construc- tion

Retrieval-augmented generation made it practical to ground
answers in external evidence rather than relying only on
model parameters [7]. Query rewriting further improved
this picture by helping align user wording with retrievable
source language when the two do not match directly [8].
In regulatory text, however, the difficulty often lies not in
locating one relevant passage but in combining several re-
lated passages into a single faithful answer. Gokhan and
Briscoe show that performance drops when answers must
be grounded across multiple passages rather than extracted
from one locally sufficient span [6]. The RIRAG shared
task reaches a similar conclusion in practice: strong sys-
tems now combine sparse retrieval, dense retrieval, rerank-
ing, and prompted answer generation to cope with long,
fragmented regulatory evidence [18].

These advances substantially improve evidence retrieval
and answer quality. Even so, they leave a central problem

177	unresolved. Better retrieval does not by itself prevent the	228
178	model from writing beyond the evidence it has retrieved.	229
179	2.3. Grounded Generation, Attribution, and Hallu-	230
180	cination Control	231
181	That problem connects regulatory question answering to the	232
182	broader literature on hallucination and attribution in lan-	233
183	guage models. Ji et al. describe hallucination as a persistent	234
184	failure mode of neural text generation, where outputs can	235
185	be unsupported, unverifiable, or false despite sounding flu-	236
186	ent and confident [9]. Niu et al. show that this risk persists	237
187	even in retrieval-augmented systems: access to retrieved	238
188	passages does not by itself guarantee that the final answer	239
189	will stay faithful to them [10]. In legal settings, the risk	240
190	is sharper still. Dahl et al. show that large language mod-	241
191	els can produce authoritative-sounding legal content that is	
192	nevertheless wrong [19]. Hu et al. improve factuality in	242
193	legal question answering through fine-tuning, but their re-	243
194	sults also make clear that factuality remains an active con-	244
195	trol problem rather than a solved by-product of larger mod-	245
196	els or better prompting [11].	246
197	For compliance applications, this matters in a very con-	247
198	crete way. A system may retrieve the correct control neigh-	248
199	borhood and still produce a final answer that is incomplete,	249
200	overstated, or false-complete. Grounded retrieval is there-	250
201	fore necessary, but it is not sufficient. The system must also	251
202	constrain how the final answer is formed.	
203	2.4. From Grounded Generation to Mechanically	252
204	Constrained Answering	253
205	Recent work has improved regulatory question answering	254
206	through stronger retrieval, reranking, and grounded answer	255
207	generation. In the regulatory setting, shared-task and bench-	256
208	mark systems typically retrieve relevant passages and then	257
209	prompt a language model to generate the final response	258
210	[18, 21]. Related work in attributed question answering and	259
211	quote-supported generation similarly aims to make model	260
212	outputs more faithful by attaching evidence to generated an-	261
213	swers [22, 23]. Post-hoc attribution methods go one step	262
214	further by revising unsupported model outputs after gener-	263
215	ation [24].	264
216	These advances are important, but they do not remove	265
217	the architectural source of the problem. In all of these set-	266
218	tings, the model still retains freedom at the point where the	267
219	final answer is written. For compliance question answer-	268
220	ing, that freedom is exactly what becomes dangerous: the	269
221	system may retrieve the correct evidence and still produce	270
222	a false-complete answer that overstates, paraphrases, or in-	271
223	vents compliance content. Our work takes a different po-	272
224	sition. We decouple probabilistic evidence selection from	
225	final answer realization. The model may help retrieve, rank,	273
226	and select evidence, but it is not allowed to freely author the	274
227	final compliance answer. Instead, the final answer is assem-	275
	bled deterministically from authoritative text and checked	276
	under an explicit citation contract.	
	3. Method: Retrieval, Citation Contract, and	
	Deterministic Answer Assembly	
	ComplianceGPT is an implemented compliance question	
	answering system for NIST SP 800-53 Rev4 and Rev5. The	
	pipeline has two conceptual layers. The first layer selects	
	evidence through version-scoped retrieval and bounded	
	model assistance. The second layer realizes the final answer	
	through deterministic assembly from canonical clause text	
	under a citation contract. This separation is the core design	
	decision of the system. The language model can help find	
	and select evidence, but it is not allowed to freely synthesize	
	the final compliance answer.	
	3.1. Canonical Clause Store and Version Guards	
	The Canonical Clause Store is the source of truth for both	
	retrieval and final answer assembly. We ingest the official	
	OSCAL representations of NIST SP 800-53 Rev4 and Rev5	
	and normalize them into clause-level records [33]. Each	
	record stores a stable source identifier, normalized clause	
	text, framework revision, clause role, and ODP metadata.	
	Rev4 and Rev5 are indexed separately. Retrieval, evidence	
	selection, and final answer assembly all use the same revi-	
	sion guard, which prevents cross-revision mixing.	
	3.2. Query Understanding and Retrieval Stack	
	To reduce terminology mismatch between user questions	
	and standard language, ComplianceGPT uses a lightweight	
	Qwen2.5 model for query understanding and controlled	
	query rewriting [34]. The rewrite is not treated as a replace-	
	ment for the original question. Earlier ablations show that	
	rewrite-only retrieval can degrade performance. In the final	
	system, query rewriting is used only as controlled support	
	inside a stronger hybrid retriever.	
	The retrieval stack has two channels over the version-	
	specific clause store.	
	Lexical retrieval. A BM25 retriever captures direct term	
	overlap and precise control language matches.	
	Dense retrieval. A bi-encoder retriever captures seman-	
	tic similarity when the user question and the standard use	
	different wording.	
	The outputs of these retrievers are fused with reciprocal	
	rank fusion, and the strongest configurations apply a cross-	
	encoder reranker to the fused candidate set. Reranking im-	
	proves precision by rescoring full query-clause pairs rather	
	than independent embeddings.	
	3.3. Retrieval Ladder	
	We evaluate seven retrieval configurations.	
	1. S1: BM25 baseline. Lexical retrieval on the original	
	user query.	

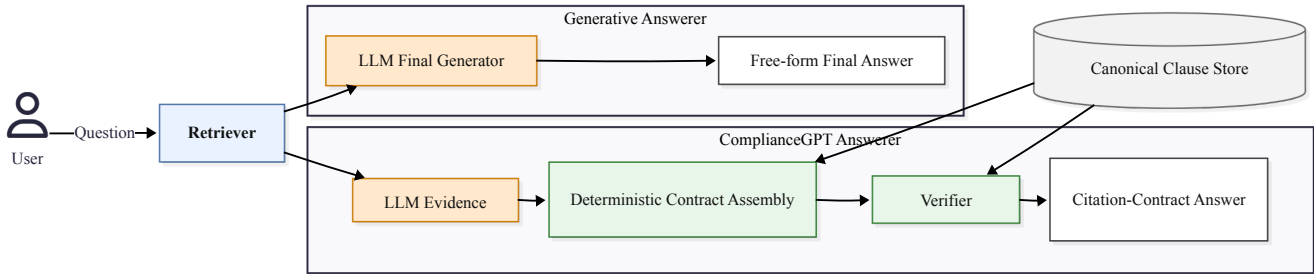


Figure 1. Comparison of Generative Answerer & ComplianceGPT Answerer

2. **S2: Dense baseline.** Dense retrieval on the original user query.
3. **S3: Rewrite-only.** Retrieval from QUR rewrites without preserving the original query.
4. **S4: QUR plus BM25.** Fusion of original-query BM25 with rewrite-based BM25.
5. **S5: Hybrid RRF.** Fusion of lexical and dense retrieval.
6. **S6: Hybrid plus reranker.** S5 followed by cross-encoder reranking.
7. **S7: ComplianceGPT retrieval.** Fusion of lexical retrieval, dense retrieval, and controlled QUR inputs followed by reranking.

3.4. Selector-Only Evidence Choice

After retrieval, ComplianceGPT does not ask the language model to write the final compliance answer. Instead, the model performs bounded evidence choice only. Given the top retrieved candidates, the selector returns the minimal set of source identifiers needed for the answer and a coarse status. The selector does not produce final user-facing prose and does not invent supporting spans. This constraint is deliberate. In compliance QA, the most dangerous failure is often not retrieval miss alone, but an unsupported completion in the final answer.

3.5. Citation Contract and Deterministic Assembly

The final answer is realized deterministically from the canonical clause text associated with the selected source identifiers. Evidence spans are copied verbatim from the Canonical Clause Store. The final contract includes the answer text, source identifiers, supporting spans, and final status. The allowed safe statuses are explicit. NO_EVIDENCE is returned when sufficient support is absent. PARAMS_REQUIRED is returned when the evidence contains unresolved organization-defined parameters in the no-profile setting. This design prevents the final stage from guessing missing values or smoothing away unresolved placeholders.

3.6. Verifier

A verifier checks the final contract against the canonical store. The checks include source identifier validity, revision consistency, evidence presence, verbatim grounding,

Table 1. Citation-contract view of the final answer object.

Field	Purpose
Revision scope	Enforces Rev4 or Rev5 consistency from retrieval through final assembly
Selected source identifiers	Defines the clause-level evidence set chosen by the selector
Supporting spans	Stores verbatim grounding from the Canonical Clause Store
Final status	Distinguishes grounded answers from NO_EVIDENCE and PARAMS_REQUIRED
Assembled answer text	Realized deterministically from canonical clause text rather than free-form generation

and ODP-related status behavior. Audit Ready Answer in this paper means that the final output passed strict contract-validity checks. It does not mean that the answer text is identical to a human-written gold response.

3.7. Matched Generative Baseline

To isolate the role of answer construction, we implement a matched generative baseline for RQ2 and RQ3. It reuses the same revision-scoped corpus, the same retrieval path, the same candidate evidence pool, and the same general model family. The substantive difference is the last mile. ComplianceGPT uses selector-only evidence choice plus deterministic citation-contract assembly. The baseline writes the final answer freely.

4. Experimental Setup

The evaluation is organized around three research layers. RQ1 studies retrieval quality. RQ2 studies final answer construction under matched retrieval conditions. RQ3 studies organization-defined parameter handling in the no-profile setting.

Table 2. Matched comparison setting for the two answerers.

Component	ComplianceGPT	Generative baseline
Revision-scoped clause store	Shared	Shared
Retrieval backbone	Shared	Shared
Candidate evidence pool	Shared	Shared
General model family	Shared	Shared
Final answer construction	Deterministic contract assembly	Free-form generation
Verifier-enforced final contract	Yes	No

4.1. Datasets

We use two manually curated gold datasets for end-to-end evaluation.

Rev5 gold set. This set contains 100 questions over NIST SP 800-53 Rev5. Among them, 63 are ODP-bearing.

Rev4 gold set. This set contains 36 questions over NIST SP 800-53 Rev4. Among them, 19 are ODP-bearing.

Each gold item includes the natural language query, the correct framework revision, the gold control target, and the gold clause support used for evaluation. Rev4 and Rev5 are reported separately because revision specificity is part of the task rather than evaluation noise.

Error Bank v1. For RQ1 retrieval analysis, we also use Error Bank v1, a diagnostic set derived from observed lexical retrieval failures. It is used to stress semantic mismatch cases and to test whether the full retrieval stack recovers cases that BM25 alone misses.

4.2. Evaluation for RQ1: Retrieval

RQ1 evaluates the S1 to S7 retrieval ladder on the gold sets and Error Bank. We report Recall at 1, 5, and 10, MRR at 10, and nDCG at 10. A retrieval result is counted as correct only when it reaches the gold target from the correct framework revision.

4.3. Evaluation for RQ2: Answer Construction

RQ2 compares two end-to-end answerers on the same datasets.

ComplianceGPT answerer. The current system uses selector-only evidence selection followed by deterministic citation-contract assembly.

Generative RAG baseline. The baseline reuses the same revision-scoped corpus, the same retrieval stack, the same candidate evidence pool, the same version guards, and

the same general model family, but replaces deterministic final assembly with free-form final answer generation.

This comparison is designed to isolate answer construction rather than retrieval. Both answerers operate over the same revision-scoped corpus, the same retrieval backbone, the same candidate evidence pool, and the same version guards. The question is whether ordinary generative final synthesis remains unsafe when the retriever is already strong.

For RQ2 we report the following metrics.

Audit Ready Answer Rate. Fraction of questions whose final answer passes strict contract-validity checks.

Right Control Found Rate. Fraction of questions where the system reaches the correct gold control.

Right Clause Found Rate. Fraction of questions where the system reaches the correct gold clause.

Full Gold Clause Coverage Rate. Fraction of questions where the complete gold clause set is recovered.

Answer Has Supporting Evidence Rate. Fraction of questions with at least one supporting evidence span.

Average Supporting Span Count. Average number of supporting evidence spans per answer.

Head-to-head paired metrics. We also report ComplianceGPT strict win rate, generative false complete versus ComplianceGPT safe warning rate, generative missed right control versus ComplianceGPT rate, and same final status rate.

4.4. Evaluation for RQ3: ODP Handling

The current answerer comparison is run in the no-profile setting. This detail is critical. When an answer depends on unresolved organization-defined parameters and no approved profile value is available, the correct behavior is to return PARAMS_REQUIRED rather than a complete-looking answer. This setup is intentionally narrow. It isolates unresolved-state safety before introducing profile-based value filling, which would otherwise blur the central failure mode.

For RQ3 we report the following metrics.

ODP Correct Handling Rate. For ODP-bearing questions in the current no-profile setting, fraction where the system correctly returns PARAMS_REQUIRED.

ODP False Complete Rate. For ODP-bearing questions, fraction where the system incorrectly returns a complete-looking OK answer despite unresolved parameters.

ODP Unresolved Detected Rate. Fraction of ODP-bearing questions where the unresolved state is surfaced explicitly.

ODP Unresolved Hidden Rate. Fraction of ODP-bearing questions where the unresolved state is suppressed in the final answer.

5. Results and Analysis

This section first establishes the retrieval foundation and then turns to the main result of the paper: under a matched retrieval setting, the decisive gain comes from citation-contract answer construction rather than from retrieval alone.

5.1. RQ1 Retrieval Foundation

The S1 to S7 ladder shows three stable facts. First, rewrite-only retrieval is not enough and can degrade performance. Second, hybrid retrieval is materially stronger than either lexical or dense retrieval alone. Third, the full S7 stack is the strongest overall configuration on the main gold sets and on Error Bank. Tables 3 through 7 summarize this foundation. On Rev5, S7 reaches Recall at 1 of 0.9000 and MRR at 10 of 0.9460. On Rev4, S7 reaches Recall at 1 of 0.9167 and MRR at 10 of 0.9583. These results justify the retrieval design, but they do not by themselves establish safe end-to-end compliance QA.

5.2. RQ2 Answer Construction Under Matched Retrieval

The central comparison is between two answerers that share the same revision-scoped corpus, retrieval backbone, candidate evidence pool, and general model family. The only substantive change is the last mile. ComplianceGPT performs selector-only evidence choice and deterministic citation-contract assembly. The baseline writes the final answer freely.

Table 8 shows the outcome. On Rev5, ComplianceGPT reaches 0.64 Audit Ready Answer rate, compared with 0.22 for the generative baseline. Right-control performance remains relatively close at 0.96 versus 0.91. Right-clause performance is 0.92 versus 0.77. Full gold clause coverage is 0.64 versus 0.48. Every ComplianceGPT answer has supporting evidence, while the baseline drops to 0.95. The same pattern appears on Rev4. Both systems find the right control at 1.00, yet ComplianceGPT reaches 0.75 Audit Ready Answer rate while the generative baseline reaches 0.222222.

This is the key empirical point of the paper. The baseline is often in the correct control neighborhood, but it still fails safe final answer construction. Retrieval quality matters, but it is not the decisive source of the end-to-end gain. The decisive source is citation-contract answer realization.

5.3. RQ3 ODP Handling

ODP-bearing questions are the sharpest safety stress test in this setting. In the no-profile condition, unresolved organization-defined parameters must remain unresolved. A system that returns an apparently complete answer in this case is making a materially different compliance decision from a system that surfaces unresolvedness explicitly.

Table 9 shows the result. ComplianceGPT handles ODP cases correctly on every ODP-bearing question in both revisions. The generative baseline does not. Its dominant failure mode is false completeness. On Rev5, ComplianceGPT reaches 1.00 ODP correct handling, while the baseline reaches 0.00 and false-completes at 0.952381. On Rev4, ComplianceGPT again reaches 1.00 ODP correct handling, while the baseline reaches 0.00 and false-completes every ODP-bearing case.

This is the strongest result of the current paper because it isolates a structural safety difference rather than a stylistic one. ComplianceGPT preserves unresolved parameters and returns PARAMS_REQUIRED when needed. The baseline frequently suppresses the unresolved state and returns an answer that looks complete.

5.4. Paired Comparison

The paired comparison in Table 10 shows that the two systems are not merely phrasing the same answer differently. They are often making different final decisions on the same questions. On Rev5, ComplianceGPT has a strict win rate of 0.44, while the rate at which the generative baseline produces a false-complete answer against a ComplianceGPT safe warning is 0.78. Same-final-status agreement is only 0.17. The Rev4 pattern is similar, with a strict win rate of 0.527778, false-complete versus safe-warning rate of 0.777778, and same-final-status agreement of 0.222222.

5.5. Failure Analysis and Limits

The current experiments establish a strong architectural result, but they do not yet make ComplianceGPT perfect. The remaining gap is visible in the difference between right-control performance and Audit Ready Answer rate. On Rev5, ComplianceGPT finds the right control at 0.96 but reaches 0.64 Audit Ready Answer rate. On Rev4, it finds the right control at 1.00 but reaches 0.75 Audit Ready Answer rate. This means that retrieval success alone does not guarantee a fully valid final answer, even in the safer architecture.

The present paper does not yet provide a full quantitative taxonomy of the remaining ComplianceGPT failures. The most plausible categories are retrieval miss, selector miss, partial clause coverage, verifier failure, and ambiguity in the gold support specification. That missing breakdown is a limitation of the current draft and should be added in a later revision.

The paper is also intentionally narrow in scope. The reported results cover NIST SP 800-53 Rev4 and Rev5 only, with moderate gold-set sizes and a no-profile ODP setting. The current evidence therefore supports a bounded conclusion: for these two NIST revisions, strong retrieval is necessary but not sufficient, and replacing free-form final synthesis with citation-contract answer assembly materially im-

Table 3. Final Consolidated Results — Recall@1

System	Rev. 5 n=100	Rev. 5 ODP n=63	Rev. 4 n=36	Rev. 4 ODP n=19	Error Bank Rev. 5, n=24	Error Bank Rev. 4, n=13
S1 - BM25 Baseline	0.7600	0.7778	0.6389	0.7368	0.0000	0.0000
S2 - Dense Baseline	0.8400	0.8254	0.8889	0.8421	0.6667	0.8462
S3 - Rewrite-Only	0.5100	0.5238	0.5833	0.7368	0.2083	0.0769
S4 - QUR-RRF	0.7800	0.8413	0.6944	0.8421	0.2917	0.1538
S5 - Hybrid RRF S1+S2	0.8900	0.9048	0.8056	0.8947	0.5417	0.4615
S6 - Hybrid + Rerank	0.8000	0.7619	0.8056	0.6316	0.5417	0.8462
S7 - ComplianceGPT	0.9000	0.9206	0.9167	1.0000	0.7083	0.7692

Table 4. Final Consolidated Results — Recall@5

System	Rev. 5 n=100	Rev. 5 ODP n=63	Rev. 4 n=36	Rev. 4 ODP n=19	Error Bank Rev. 5, n=24	Error Bank Rev. 4, n=13
S1 - BM25 Baseline	0.9600	0.9683	0.9167	0.9474	0.8333	0.7692
S2 - Dense Baseline	1.0000	1.0000	1.0000	1.0000	1.0000	1.0000
S3 - Rewrite-Only	0.7800	0.8254	0.9167	0.8947	0.5417	0.7692
S4 - QUR-RRF	0.9600	0.9683	0.9167	0.9474	0.8750	0.7692
S5 - Hybrid RRF S1+S2	0.9900	1.0000	0.9722	0.9474	0.9583	0.9231
S6 - Hybrid + Rerank	0.9600	0.9524	1.0000	1.0000	0.8333	1.0000
S7 - ComplianceGPT	0.9900	1.0000	1.0000	1.0000	0.9583	1.0000

proves audit-ready behavior and ODP-safe handling under matched retrieval conditions.

6. Conclusion

This paper presents ComplianceGPT as a working citation-contract architecture for mechanically verifiable compliance question answering over NIST SP 800-53 Rev4 and Rev5. The retrieval ladder establishes a strong version-aware retrieval foundation, but the central result is not retrieval alone. Under matched retrieval conditions, the answerer comparison shows that the decisive gain comes from deterministic citation-contract assembly rather than free-form final generation.

The strongest evidence comes from organization-defined parameters. In the no-profile setting, ComplianceGPT preserves unresolved parameter states and returns PARAMS_REQUIRED. The matched generative baseline frequently suppresses that unresolved state and returns complete-looking answers. This produces a large gap in Audit Ready Answer rate and an even sharper gap in ODP-safe behavior across both revisions.

The conclusion is intentionally narrow. We do not claim all-framework generality or state-of-the-art performance across arbitrary compliance corpora. We show that, for NIST SP 800-53 Rev4 and Rev5, a clause-level citation-contract architecture can convert strong retrieval into safer and mechanically checkable final answers.

7. Future Work

The next technical step is profile-aware ODP resolution under explicit policy control. The current paper evaluates the no-profile setting because it exposes the core safety question most clearly. The next stage is to add controlled profile filling where approved organizational values exist while preserving verbatim evidence and clear separation between source text and filled values. A second step is deeper failure analysis, including a quantitative breakdown of remaining ComplianceGPT errors into retrieval miss, selector miss, partial clause coverage, verifier failure, and gold ambiguity. A third step is broader evaluation beyond the current NIST SP 800-53 Rev4 and Rev5 setting, including larger gold sets, harder ODP cases, more adversarial scenario phrasing, and eventual transfer tests on additional compliance corpora such as HIPAA Security Rule and PCI DSS.

References

- [1]
- [2] J. Jain, N. Dhanasekaran, and M. T. Diab, “From Complexity to Clarity: AI/NLP’s Role in Regulatory Compliance,” in *Findings of the Association for Computational Linguistics: ACL 2025*, pp. 26629–26641, 2025, doi: 10.18653/v1/2025.findings-acl.1366. 1
- [3] R. Kruiper, B. Kumar, R. Watson, F. Sadeghineko, A. Gray, and I. Konstantas, “A platform-based Natural Language processing-driven strategy for digitalising regulatory compliance processes for the built environment,” *Advanced En-*

Table 5. Final Consolidated Results — Recall@10

System	Rev. 5 n=100	Rev. 5 ODP n=63	Rev. 4 n=36	Rev. 4 ODP n=19	Error Bank Rev. 5, n=24	Error Bank Rev. 4, n=13
S1 - BM25 Baseline	0.9800	0.9841	0.9167	0.9474	0.9167	0.7692
S2 - Dense Baseline	1.0000	1.0000	1.0000	1.0000	1.0000	1.0000
S3 - Rewrite-Only	0.8600	0.8889	0.9167	0.8947	0.6667	0.7692
S4 - QUR-RRF	0.9800	0.9841	0.9167	0.9474	0.9167	0.7692
S5 - Hybrid RRF S1+S2	0.9900	1.0000	1.0000	1.0000	0.9583	1.0000
S6 - Hybrid + Rerank	1.0000	1.0000	1.0000	1.0000	1.0000	1.0000
S7 - ComplianceGPT	1.0000	1.0000	1.0000	1.0000	1.0000	1.0000

Table 6. Final Consolidated Results — nDCG@10

System	Rev. 5 n=100	Rev. 5 ODP n=63	Rev. 4 n=36	Rev. 4 ODP n=19	Error Bank Rev. 5, n=24	Error Bank Rev. 4, n=13
S1 - BM25 Baseline	0.8841	0.8946	0.7885	0.8559	0.5172	0.4142
S2 - Dense Baseline	0.9292	0.9221	0.9554	0.9348	0.8418	0.9432
S3 - Rewrite-Only	0.6846	0.7107	0.7735	0.8190	0.4393	0.4580
S4 - QUR-RRF	0.8827	0.9197	0.8206	0.9016	0.6128	0.5032
S5 - Hybrid RRF S1+S2	0.9531	0.9649	0.9088	0.9455	0.8046	0.7476
S6 - Hybrid + Rerank	0.9050	0.8892	0.9246	0.8571	0.7564	0.9432
S7 - ComplianceGPT	0.9597	0.9707	0.9692	1.0000	0.8781	0.9148

- 573 *gineering Informatics*, vol. 62, Art. 102653, 2024, doi:
574 10.1016/j.aei.2024.102653. 1
- 575 [4] S. Robertson and H. Zaragoza, “The Probabilistic Relevance
576 Framework: BM25 and Beyond,” *Foundations and Trends in*
577 *Information Retrieval*, vol. 3, no. 4, pp. 333–389, 2009, doi:
578 10.1561/15000000019. 1
- 579 [5] J. S. Rayo Mosquera, C. R. De La Rosa Peredo, and M. Gar-
580 rido Cordoba, “A Hybrid Approach to Information Retrieval
581 and Answer Generation for Regulatory Texts,” in *Proceed-*
582 *ings of the 1st Regulatory NLP Workshop (RegNLP 2025)*,
583 Abu Dhabi, UAE, 2025, pp. 31–35. 1
- 584 [6] T. Gokhan and T. Briscoe, “Grounded Answers from
585 Multi-Passage Regulations: Learning-to-Rank for Regu-
586 latory RAG,” in *Proceedings of the Natural Legal Language*
587 *Processing Workshop 2025*, Suzhou, China, 2025, pp. 135–
588 146, doi: 10.18653/v1/2025.nllp-1.10. 1, 2
- 589 [7] P. Lewis, E. Perez, A. Piktus, F. Petroni, V. Karpukhin, N.
590 Goyal, H. Küttler, M. Lewis, W.-t. Yih, T. Rocktäschel, S.
591 Riedel, and D. Kiela, “Retrieval-Augmented Generation for
592 Knowledge-Intensive NLP Tasks,” in *Advances in Neural*
593 *Information Processing Systems*, vol. 33, 2020, pp. 9459–
594 9474. 1, 2
- 595 [8] X. Ma, Y. Gong, P. He, H. Zhao, and N. Duan, “Query
596 Rewriting in Retrieval-Augmented Large Language Mod-
597 els,” in *Proceedings of the 2023 Conference on Empirical*
598 *Methods in Natural Language Processing*, Singapore, 2023,
599 pp. 5303–5315, doi: 10.18653/v1/2023.emnlp-main.322. 1,
600 2
- 601 [9] Z. Ji, N. Lee, R. Frieske, T. Yu, D. Su, Y. Xu, E. Ishii, Y.
602 Bang, D. Chen, W. Dai, H. S. Chan, A. Madotto, and P. Fung,
“Survey of Hallucination in Natural Language Generation,”
ACM Computing Surveys, vol. 55, no. 12, Art. 248, 2023,
doi: 10.1145/3571730. 1, 3
- [10] C. Niu, Y. Wu, J. Zhu, S. Xu, K. Shum, R. Zhong, J. Song,
and T. Zhang, “RAGTruth: A Hallucination Corpus for De-
veloping Trustworthy Retrieval-Augmented Language Mod-
els,” in *Proceedings of the 62nd Annual Meeting of the As-*
sociation for Computational Linguistics (Volume 1: Long
Papers), Bangkok, Thailand, 2024, pp. 10862–10878, doi:
10.18653/v1/2024.acl-long.585. 1, 3
- [11] Y. Hu, L. Gan, W. Xiao, K. Kuang, and F. Wu, “Fine-tuning
Large Language Models for Improving Factuality in Legal
Question Answering,” in *Proceedings of the 31st Interna-*
tional Conference on Computational Linguistics, Abu Dhabi,
UAE, 2025, pp. 4410–4427. 1, 3
- [12] Joint Task Force Transformation Initiative, “Security and
Privacy Controls for Federal Information Systems and Or-
ganizations,” National Institute of Standards and Tech-
nology, Gaithersburg, MD, NIST Special Publication
(SP) 800-53, Rev. 4, Apr. 2013. [Online]. Available:
https://doi.org/10.6028/NIST.SP.800-53r4 2
- [13] Joint Task Force, “Security and Privacy Controls for Infor-
mation Systems and Organizations,” National Institute of
Standards and Technology, Gaithersburg, MD, NIST Special
Publication (SP) 800-53, Rev. 5, Sep. 2020. [Online]. Avail-
able: https://doi.org/10.6028/NIST.SP.800-53r5 2
- [14] I. Chalkidis, I. Androutsopoulos, and A. Michos, “Obliga-
tion and Prohibition Extraction Using Hierarchical RNNs,”
in *Proceedings of the 56th Annual Meeting of the Asso-*
ciation for Computational Linguistics (Volume 2: Short

Table 7. Final Consolidated Results — MRR@10

System	Rev. 5 n=100	Rev. 5 ODP n=63	Rev. 4 n=36	Rev. 4 ODP n=19	Error Bank Rev. 5, n=24	Error Bank Rev. 4, n=13
S1 - BM25 Baseline	0.8518	0.8644	0.7454	0.8246	0.3827	0.2949
S2 - Dense Baseline	0.9053	0.8960	0.9398	0.9123	0.7896	0.9231
S3 - Rewrite-Only	0.6287	0.6532	0.7245	0.7939	0.3667	0.3526
S4 - QUR-RRF	0.8509	0.8981	0.7880	0.8860	0.5132	0.4128
S5 - Hybrid RRF S1+S2	0.9400	0.9524	0.8790	0.9286	0.7500	0.6648
S6 - Hybrid + Rerank	0.8742	0.8531	0.8981	0.8070	0.6807	0.9231
S7 - ComplianceGPT	0.9460	0.9603	0.9583	1.0000	0.8375	0.8846

Table 8. Full answerer comparison under matched retrieval. Audit Ready Answer means the final output passed strict contract-validity checks.

Framework	System	Audit Ready	Right Control	Right Clause	Gold Coverage	Evidence Rate	Avg Span Count
Rev5	ComplianceGPT	0.64	0.96	0.92	0.64	1.00	4.01
Rev5	Generative RAG baseline	0.22	0.91	0.77	0.48	0.95	3.39
Rev4	ComplianceGPT	0.75	1.00	0.972222	0.75	1.00	4.222222
Rev4	Generative RAG baseline	0.222222	1.00	0.833333	0.555556	1.00	2.722222

- Papers), Melbourne, Australia, 2018, pp. 254–259, doi: 10.18653/v1/P18-2041. 2
- [15] I. Chalkidis, M. Fergadiotis, N. Manginas, E. Katakalogou, and P. Malakasiotis, “Regulatory Compliance through Doc2Doc Information Retrieval: A Case Study in EU/UK Legislation where Text Similarity has Limitations,” in *Proceedings of the 16th Conference of the European Chapter of the Association for Computational Linguistics: Main Volume*, Online, 2021, pp. 3498–3511, doi: 10.18653/v1/2021.eacl-main.305. 2
- [16] S. Abualhaija, C. Arora, A. Sleimi, and L. C. Briand, “Automated Question Answering for Improved Understanding of Compliance Requirements: A Multi-Document Study,” in *2022 IEEE 30th International Requirements Engineering Conference (RE)*, 2022, pp. 39–50, doi: 10.1109/RE54965.2022.00011. 2
- [17] T. Gokhan, K. Wang, I. Gurevych, and T. Briscoe, “RIRAG: Regulatory Information Retrieval and Answer Generation,” arXiv preprint arXiv:2409.05677, 2024. 2
- [18] T. Gokhan, K. Wang, I. Gurevych, and T. Briscoe, “Shared Task RIRAG-2025: Regulatory Information Retrieval and Answer Generation,” in *Proceedings of the 1st Regulatory NLP Workshop (RegNLP 2025)*, Abu Dhabi, UAE, 2025, pp. 1–4. 2, 3
- [19] M. Dahl, V. Magesh, M. Suzgun, and D. E. Ho, “Large Legal Fictions: Profiling Legal Hallucinations in Large Language Models,” *Journal of Legal Analysis*, vol. 16, no. 1, pp. 64–93, 2024, doi: 10.1093/jla/laae003. 3
- [20] Joint Task Force, “Assessing Security and Privacy Controls in Information Systems and Organizations,” National Institute of Standards and Technology, Gaithersburg, MD, NIST Special Publication (SP) 800-53A, Rev. 5, Jan. 2022. [Online]. Available: <https://doi.org/10.6028/NIST.SP.800-53Ar5>
- [21] D. Quinn, S. P. Pai, I. Yousfi, N. Pudota, and S. Bhattacharya, “Regulatory Question-Answering Using Generative AI,” in *Proceedings of the 1st Regulatory NLP Workshop (RegNLP 2025)*, Abu Dhabi, UAE, 2025, pp. 102–106. 3
- [22] B. Bohnet, V. Q. Tran, P. Verga, R. Aharoni, D. Andor, L. Baldini Soares, M. Ciaramita, J. Eisenstein, K. Ganchev, J. Herzig, K. Hui, T. Kwiatkowski, J. Ma, J. Ni, L. S. Saralegui, T. Schuster, W. W. Cohen, M. Collins, D. Das, D. Metzler, S. Petrov, and K. Webster, “Attributed Question Answering: Evaluation and Modeling for Attributed Large Language Models,” arXiv preprint arXiv:2212.08037, 2022. 3
- [23] J. Menick, M. Trebacz, V. Mikulik, J. Aslanides, F. Song, M. Chadwick, M. Glaese, S. Young, L. Campbell-Gillingham, G. Irving, and N. McAleese, “Teaching Language Models to Support Answers with Verified Quotes,” arXiv preprint arXiv:2203.11147, 2022. 3
- [24] L. Gao, Z. Dai, P. Pasupat, A. Chen, A. T. Chaganty, Y. Fan, V. Y. Zhao, N. Lao, H. Lee, D.-C. Juan, and K. Guu, “RARR: Researching and Revising What Language Models Say, Using Language Models,” in *Proceedings of the 61st Annual Meeting of the Association for Computational Linguistics (Volume 1: Long Papers)*, Toronto, Canada, 2023, pp. 16477–16508, doi: 10.18653/v1/2023.acl-long.910. 3
- [25] A. Asai, Z. Wu, Y. Wang, A. Sil, and H. Hajishirzi, “Self-RAG: Learning to Retrieve, Generate, and Critique through Self-Reflection,” in *Proc. Int. Conf. Learn. Representations (ICLR)*, 2024.
- [26] L. Huang, X. Feng, W. Ma, Y. Gu, W. Zhong, X. Feng, W. Yu, W. Peng, D. Tang, D. Tu, and B. Qin, “Learning Fine-Grained Grounded Citations for Attributed Large Lan-

Placeholder for the ODP case study figure.
Recommended content: one real ODP-bearing query, the governing clause text with the unresolved placeholder highlighted, a generative baseline output that appears complete, and a ComplianceGPT output that returns PARAMS_REQUIRED with grounded spans.

Figure 2. Placeholder for a qualitative ODP case study. This figure should show that the key difference is not retrieval neighborhood alone, but whether unresolved organization-defined parameters are surfaced or hidden in the final answer.

Table 9. ODP handling under the no-profile condition.

Framework	System	ODP Questions	ODP Correct	ODP False Complete	Unresolved Detected	Unresolved Hidden
Rev5	ComplianceGPT	63	1.00	0.000000	1.000000	0.000000
Rev5	Generative RAG baseline	63	0.00	0.952381	0.365079	0.634921
Rev4	ComplianceGPT	19	1.00	0.000000	1.000000	0.000000
Rev4	Generative RAG baseline	19	0.00	1.000000	0.315789	0.684211

- guage Models,” in *Findings of the Association for Computational Linguistics: ACL 2024*, Bangkok, Thailand, 2024, pp. 14095–14113, doi: 10.18653/v1/2024.findings-acl.838.
- [27] I. Zimmerman, J. Tredup, E. Selfridge, and J. Bradley, “Two-tiered Encoder-based Hallucination Detection for Retrieval-Augmented Generation in the Wild,” in *Proc. 2024 Conf. Empirical Methods in Natural Language Processing: Industry Track (EMNLP Industry Track)*, Miami, FL, USA, 2024, pp. 8–22, doi: 10.18653/v1/2024.emnlp-industry.2.
- [28] C. Niu, Y. Wu, J. Zhu, S. Xu, K. Shum, R. Zhong, J. Song, and T. Zhang, “RAGTruth: A Hallucination Corpus for Developing Trustworthy Retrieval-Augmented Language Models,” in *Proc. 62nd Annu. Meeting Assoc. Comput. Linguistics (ACL), Vol. 1: Long Papers*, Bangkok, Thailand, 2024, pp. 10862–10878, doi: 10.18653/v1/2024.acl-long.585.
- [29] S.-Q. Yan, J.-C. Gu, Y. Zhu, and Z.-H. Ling, “Corrective Retrieval Augmented Generation,” *arXiv preprint arXiv:2401.15884*, 2024, doi: 10.48550/arXiv.2401.15884.
- [30] W. Li, J. Li, W. Ma, and Y. Liu, “Citation-Enhanced Generation for LLM-based Chatbots,” in *Proc. 62nd Annu. Meeting Assoc. Comput. Linguistics (ACL), Vol. 1: Long Papers*, Bangkok, Thailand, 2024, pp. 1451–1466, doi: 10.18653/v1/2024.acl-long.79.
- [31] J. Zhang, Y. Bai, X. Lv, W. Gu, D. Liu, M. Zou, S. Cao, L. Hou, Y. Dong, L. Feng, and J. Li, “LongCite: Enabling LLMs to Generate Fine-grained Citations in Long-Context QA,” in *Findings of the Association for Computational Linguistics: ACL 2025*, Vienna, Austria, 2025, pp. 5098–5122, doi: 10.18653/v1/2025.findings-acl.264.
- [32] J. Song, X. Wang, J. Zhu, Y. Wu, X. Cheng, R. Zhong, and C. Niu, “RAG-HAT: A Hallucination-Aware Tuning Pipeline for LLM in Retrieval-Augmented Generation,” in *Proc. 2024 Conf. Empirical Methods in Natural Language Processing: Industry Track (EMNLP Industry Track)*, Miami, FL, USA, 2024, pp. 1548–1558, doi: 10.18653/v1/2024.emnlp-industry.113.
- [33] National Institute of Standards and Technology, “OSCAL: Open Security Controls Assessment Language,” [Online]. Available: <https://pages.nist.gov/OSCAL/>. [Accessed: Sep. 07, 2025]. 3
- [34] Qwen Team, “Qwen2.5: A Party of Foundation Models,” Qwen Blog, Sep. 2024. [Online]. Available: <https://qwenlm.github.io/blog/qwen2.5/> 3

Table 10. Paired answerer comparison.

Framework	Strict Win	False Complete vs Safe	Missed Right Control	Same Status
Rev5	0.440000	0.780000	0.05	0.170000
Rev4	0.527778	0.777778	0.00	0.222222